

Corrigé : Déploiement de Windows LAPS (DSRM / Tier 0)

Ce document détaille les commandes, les configurations et les résultats attendus pour la sécurisation du compte DSRM via le LAPS natif de Windows Server.

PARTIE 1 : Préparation de l'Active Directory pour LAPS

1.1 Extension du schéma

Update-LapsADSchema -Verbose

- **Ce qu'il s'est passé sous le capot :** Contrairement à l'ancien LAPS, cette commande native prépare l'AD à recevoir des mots de passe **chiffrés**. De nouveaux attributs (comme *msLAPS-EncryptedPassword*) ont été ajoutés à la définition des objets "Ordinateur".

1.2 Création du groupe autorisé

- Vous avez créé le groupe *Admins_LAPS_Tier0* et vous y avez ajouté votre compte *Administrateur*. Ce groupe est le seul "détenteur de la clé" pour déchiffrer le mot de passe DSRM.

PARTIE 2 : Sécurisation des ACLs (Le Cloisonnement)

C'est l'étape la plus critique pour un audit de sécurité (Rupture des chemins de contrôle).

Commandes exécutées :

Autorise le Contrôleur de domaine à écrire son mot de passe

Set-LapsADComputerSelfPermission -Identity "Domain Controllers"

Autorise UNIQUEMENT le groupe Tier 0 à lire et déchiffrer

Set-LapsADReadPasswordPermission -Identity "Domain Controllers" -AllowedPrincipal

"Admins_LAPS_Tier0"

- **Le point de vérification (ADSI Edit) :** En allant dans l'onglet Sécurité > Avancé de l'Unité d'Organisation *Domain Controllers*, vous avez vérifié que les groupes par défaut du domaine n'avaient pas le droit *Lire toutes les propriétés*. L'étanchéité de l'Unité d'Organisation est garantie.

PARTIE 3 : Configuration de la Stratégie (GPO)

Emplacement : *Configuration ordinateur > Stratégies > Modèles d'administration > Système > LAPS*

Paramètres configurés et justifiés :

1. **Configurer le répertoire de sauvegarde :** *Active Directory*.
2. **Activer la sauvegarde du mot de passe pour les comptes DSRM :** *Activé*. (C'est le paramètre qui indique au moteur LAPS de ne pas chercher un compte administrateur local inexistant, mais de cibler spécifiquement la clé de registre de la Backdoor DSRM).
3. **Paramètres de mot de passe :** *Activé* (Lettres, chiffres, symboles / 20 caractères / 30 jours).
4. **Activer le chiffrement des mots de passe :** *Activé*. (Obligatoire pour l'ANSSI : empêche la compromission des mots de passe en cas de vol du fichier physique *ntds.dit*).
5. **Configurer les expéditeurs autorisés à déchiffrer les mots de passe :** *FORMATION\Admins_LAPS_Tier0*.

PARTIE 4 : Validation et Preuve d'Audit

Commandes pour forcer l'application :

gpupdate /force

Invoke-LapsPolicyProcessing -Verbose

Validation 1 : Vue Opérationnelle (Ce que voit l'Admin Tier 0)

- Dans *dsa.msc* (Utilisateurs et ordinateurs Active Directory), les propriétés du Contrôleur de Domaine affichent un onglet **LAPS**.

- Le mot de passe est lisible en clair, car votre session actuelle appartient au groupe *Admins_LAPS_Tier0* configuré dans la GPO. La console a décrypté la donnée à la volée pour vous.

Validation 2 : Vue d'Audit (Ce que verrait un attaquant ou un admin non autorisé)

- Dans *adsiedit.msc* (Modification ADSI), en regardant les propriétés brutes de l'objet du DC.
- L'attribut *msLAPS-Password* (utilisé par l'ancien LAPS pour stocker en clair) est **vide**.
- L'attribut *msLAPS-EncryptedPassword* contient un long blob hexadécimal (la donnée chiffrée).
- **Conclusion :** Même si un attaquant accède à la base de données, la porte dérobée DSRM lui reste cryptographiquement inaccessible.